

means that its integrity would be compromised if it were to be found without a cap. Integrity also refers to authorised changes in its definition, e.g., if the entire world accepts a bottle as one without a cap, a bottle with one would then be non-integral or would have lost its integrity.



Note: Integrity not only refers to the property of wholeness but also refers to authorised changes only.

A monitoring system is a collection of tools that, well, monitors something. That 'something' could be a set of files, folders, or the entire hard disk. Monitoring systems have been traditionally used to observe and report anomalies (any un-authorised or dangerous changes) in a system so that these can be corrected. Traditionally, those anomalies were almost always related to the operational aspects, like the system crashing or shutting down abruptly, filling hard disk space, etc; however, thanks to the recent advances in the field of information security and as a possible response, every standard worth its salt mentions the term 'monitoring' in it.

A file integrity monitoring system monitors a filesystem or a sub-section thereof (like a folder or sub-folder) or even specific files for any change, and alerts people about it so that the changes can be studied and acted upon if an anomaly is found.



Note: An information security incident like data theft, data change, a system crash, etc, takes a lot out of an organisation as far as recovery and loss of crucial business time is concerned. Systems to monitor file integrity come handy in such cases, helping to perform root cause analysis and to eradicate the problem.

How a file integrity monitoring system works

Typically, after these tools are installed, they do the following tasks:

1. Take a snapshot of the system, usually in the form of hashes, the locations being configurable. Although the exact properties change from tool to tool, on the whole, the following properties, usually configurable, are collected to form a baseline: path and filename, date and time-stamp of creation/last modification/last accessed, permissions, ownership, size, etc. The baseline is created by creating a hash of the object (file/folder, etc), which will be recorded by the tool.
 2. Keep checking the system periodically (the frequency is usually configurable) for any changes since the last check. The tool takes another snapshot, generates a hash, and checks the hash against the earlier hash that was recorded by it.
 3. Send reports to stakeholders if any change is observed. If the hashes do not match, it means the file or folder was changed and an alarm is raised.
- These systems come in two flavours:
1. Agent-based, where an agent (client) is installed on all desktops, laptops and systems, which frequently checks for

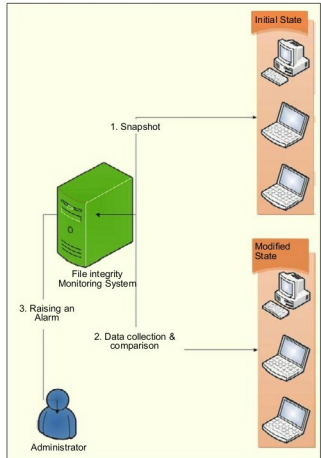


Figure 1: How a file integrity monitoring system works

- any changes to the selected areas and reports to the server.
2. Agent-less, where a server scans all desktops, laptops and systems on a periodic basis, for any changes since the last check.

Some of the open source file integrity monitoring systems are: OSSEC, Samhain, Osiris, AIDE (Advanced Intrusion Detection Environment), etc.

Implementing a file integrity monitoring system not only helps in identifying a possible system anomaly in progress, but can also provide crucial insights into system vulnerabilities so that they can be addressed. The logs provide learning that can be used to thwart a malicious user's attempt to compromise the system. Of course, compliance becomes the icing on the cake (a mere side effect, not a *raison d'être*), with the security of the system being of primary concern. 

By: M S Sripathi

The author is an ISO 27001 and HIPAA compliant ISMS implementer, who is also keenly aware of more dangerous words like SSAE16, SOX, Do Not Call, ISO 20000-1, ITIL, CoBIT, etc. A CISA (Certified Information Systems Auditor), his aim is to internalise all ISMS, technical and process aspects, so that he can build a robust ISMS for organisations. He can be contacted through his LinkedIn profile <http://in.linkedin.com/in/sripathi/>